

Projecto de Segurança de Sistemas Informáticos

Descrição Geral

O objetivo deste projeto é o desenvolvimento de um sistema de conversação (*chat*) que garanta a segurança das comunicações através de *End-to-End Encryption* (E2EE).

O sistema deve permitir que os utilizadores troquem mensagens com garantias estritas de confidencialidade, integridade e autenticidade, assegurando que o conteúdo das comunicações permanece inacessível a terceiros, incluindo o servidor que intermedeia o serviço. A implementação deve ser feita em Python, utilizando obrigatoriamente a biblioteca `cryptography` para a implementação de primitivas criptográficas.

Arquitetura do Sistema

O sistema baseia-se num modelo cliente-servidor, onde o servidor atua como um ponto central de coordenação e o cliente como a interface de cada utilizador.

- **Servidor:** Deve funcionar continuamente, aguardando conexões de clientes. É responsável pela gestão de utilizadores, encaminhamento de mensagens e armazenamento de metadados necessários (como listas de contactos). Deve garantir a persistência dos dados dos utilizadores com o mesmo rigor de segurança aplicado às mensagens.
- **Cliente:** Cada utilizador utiliza uma instância da aplicação cliente. Após estabelecer uma conexão segura com o servidor, a aplicação deve funcionar como um interpretador de comandos textuais, permitindo o envio/receção de mensagens e gestão de contactos. Detalhes concretos sobre os comandos ficam ao critério dos alunos.
- **Identidade:** Cada utilizador possui um identificador único. O suporte (ou não) de múltiplas sessões simultâneas para o mesmo utilizador fica ao critério dos alunos.
- **Comunicação:** Recomenda-se a utilização de sockets TCP para a comunicação entre entidades. Embora o projeto possa ser apenas executado localmente (`localhost`), a arquitetura deve prever a separação lógica entre cliente e servidor.

Requisitos de Segurança

A segurança é o pilar central deste projeto. Os alunos são responsáveis por desenhar e implementar o protocolo de segurança, respeitando os seguintes pontos:

- Assume-se que o servidor é honesto mas curioso, i.e., confia-se no servidor para efeitos de integridade e da implementação dos aspetos funcionais e de gestão de identidades, mas não para efeitos de confidencialidade dos dados armazenados e trocados.
- Assume-se que um atacante pode efetuar ataques de *man-in-the-middle* e tentar comprometer ativamente a rede de comunicação. Dessa forma, a confidencialidade e integridade de todas as comunicações e informações dos utilizadores devem ser sempre asseguradas.
- A autenticidade de toda a comunicação entre utilizadores e servidor deve também ser assegurada. No design mais simples, assume-se que todos os intervenientes terão pré-partilhado as suas identidades entre si de forma confiável. Utilização de PKI ou outras formas de gestão de identidades são considerados uma valorização.

Os alunos devem escolher as primitivas criptográficas que melhor se adaptem aos requisitos de segurança (ex: protocolos de troca de chaves, algoritmos de cifragem simétrica e modos de operação).

Valorizações

O projeto apresentado oferece suficiente liberdade para permitir aos grupos interessados incluir melhorias em termos tanto de funcionalidade como de garantias de segurança. Os grupos são incentivados a identificar e implementar essas melhorias. A título de exemplo, algumas funcionalidades mais avançadas poderão ser:

- Mensagens Offline: O servidor armazena mensagens cifradas quando o destinatário não está ligado, entregando-as assim que este fique online.
- Entidade de Certificação (PKI): O servidor central age também como uma Autoridade de Certificação (CA) *self-signed*, que emite certificados digitais associados à identidade dos utilizadores e que serve como *root of trust* para a validação dos mesmos.
- Modo Descentralizado (PGP-like): Capacidade de os clientes comunicarem diretamente (ou de forma assíncrona) sem dependência absoluta do servidor central.
- Mensagens de Grupo: Implementação de chats multi-utilizador com gestão de controlo de acessos e partilha segura de chaves de grupo.
- Forward secrecy: mesmo que um atacante descubra uma chave, não consegue decifrar comunicações passadas.

Relatório

O projeto deve ser acompanhado por um relatório escrito diretamente em Markdown, que documente todo o processo de desenvolvimento. O relatório deve ser estruturado nos seguintes pontos:

- Descrição detalhada da arquitetura da solução, fluxos de comunicação e funcionalidades implementadas (incluindo as valorizações). Deve incluir a metodologia de gestão de chaves.
- Descrição detalhada do modelo de segurança, contendo uma explicação fundamentada das primitivas utilizadas na solução, uma análise das garantias de segurança oferecidas e uma identificação das limitações inerentes à solução desenvolvida.
- Opcionalmente, discussão de melhorias funcionais e/ou de segurança que acabem por não ser implementadas (e.g., por falta de tempo e/ou porque envolveriam alterações substanciais na arquitetura).

Avaliação

Cada componente terá a seguinte percentagem na nota final do projeto:

Component	%
Funcionalidade	25
Segurança	35
Valorizações	25
Relatório	15

O projeto deverá ser entregue (git commits até à meia noite de Portugal Continental) até **24 de Maio de 2026**. Devem submeter todo o código do projeto e o relatório no repositório GitHub do grupo até à data limite.

Defesas

No fim do semestre, serão agendadas sessões para defesa dos trabalhos juntamente com os docentes, em horários a combinar. A presença nas defesas é obrigatória para obter aprovação. A nota das componentes práticas é provisória até à defesa final, podendo ser ajustada individualmente, com base na contribuição e desempenho de cada elemento do grupo durante a defesa.